



SAFE LABS

Przewodnik po cyberbezpieczeństwie

Uczniowie

Technikum

Seniorzy

SPIS TREŚCI

Co znajdziesz w tym ebooku

1.	Bezpieczeństwo haseł – zasady podstawowe	3
2.	Jak zapamiętać silne hasło – menedżery haseł	5
3.	Weryfikacja dwuetapowa (2FA)	7
4.	Phishing – jak go rozpoznać	8
5.	Socjotechnika – hakowanie ludzi	11
6.	Fizyczne bezpieczeństwo – co podpinasz do komputera	13
7.	OSINT – ile można wyczytać ze zdjęcia	14
8.	Co robić gdy dojdzie do ataku?	16
9.	Podsumowanie i checklisty	18

ROZDZIAŁ 1

Bezpieczeństwo haseł – zasady podstawowe

Hasło to pierwsza linia obrony Twojego konta w internecie. Większość ataków hakerskich zaczyna się właśnie od słabego lub skradzionego hasła. W tym rozdziale dowiesz się, czego **unikać** i jak tworzyć hasła, które naprawdę chronią.

Czego NIE robić z hasłem:

- ✗ **Znane schematy** – hasła typu "12345678", "zaq12wsx" czy "haslo123" są pierwszymi, które sprawdza każdy haker.
- ✗ **Krótkie hasła** – hasło krótsze niż 8 znaków jest łamane w ciągu sekund przez atak bruteforce.
- ✗ **Dane osobowe** – imię własne, psa, kota, data urodzenia – to informacje łatwe do znalezienia w social mediach.
- ✗ **To samo hasło wszędzie** – wyciek z jednego serwisu oznacza, że haker ma dostęp do wszystkich Twoich kont.

⚠ **Wyciek bazy danych jednego serwisu automatycznie kompromituje wszystkie konta, gdzie użyłeś tego samego hasła. Używaj unikalnego hasła dla każdego serwisu.**

Zasady silnego hasła:

- ✓ Minimum **12 znaków** – każdy dodatkowy znak wykładniczo wydłuża czas łamania.
- ✓ Mieszaj **wielkie i małe litery**, cyfry oraz znaki specjalne (!@#\$%).
- ✓ **Unikalność** – inne hasło dla każdego serwisu, konta, aplikacji.
- ✓ Nie używaj **słownikowych słów** – hasła słownikowe są łamane w sekundy.
- ✓ Rozważ **frazę hasłową**: np. **Pies!Lubi@Chodzić 3Razy** – łatwa do zapamiętania, trudna do złamania.

✓ **Hasło „Pies!Lubi@Chodzić3Razy” ma ponad 20 znaków i łączy wszystkie kategorie. Złamanie go metodą bruteforce zajęłoby miliony lat.**

Co to jest atak Bruteforce?

Bruteforce to metoda polegająca na automatycznym sprawdzaniu wszystkich możliwych kombinacji znaków, aż do znalezienia właściwego hasła. Nowoczesne komputery są w stanie sprawdzać miliardy kombinacji na sekundę.

Długość hasła	Znaki	Czas łamania
6 znaków	tylko cyfry	< 1 sekunda
8 znaków	małe litery	kilka minut
8 znaków	litery + cyfry	kilka godzin
12 znaków	wszystkie typy	dziesiątki lat
16+ znaków	wszystkie typy	miliony lat

* Wartości przybliżone dla typowego atakującego z dostępem do GPU.

ROZDZIAŁ 2

Jak zapamiętać silne hasło – menedżery haseł

Nie musisz pamiętać dziesiątek silnych haseł. Menedżer haseł pamięta je za Ciebie – Ty pamiętasz tylko jedno, główne hasło do menedżera.

Wbudowane menedżery haseł:

Platforma	Menedżer haseł	Gdzie znaleźć
Google / Android / Chrome	Google Password Manager	passwords.google.com
Apple / iPhone / Mac / Safari	iCloud Keychain	Ustawienia → Hasła
Windows / Edge	Microsoft Authenticator	Ustawienia Edge → Hasła

Jak działa menedżer haseł:

- ▶ **Generuje** silne, unikalne hasła dla każdego serwisu automatycznie.
- ▶ **Przechowuje** je w zaszyfrowanym skarbku – nawet producent menedżera nie zna Twoich haseł.
- ▶ **Autouzupełnia** dane logowania w przeglądarkach i aplikacjach.
- ▶ **Synchronizuje** hasła między Twoimi urządzeniami (telefon, komputer, tablet).
- ▶ **Alarmuje**, gdy jedno z Twoich haseł wycieka w internecie.

✓ **Hasła generowane przez menedżer wyglądają tak:**
„xK9#mP2\$vL7@nQ”. Nikt ich nie zapamięta – i o to chodzi! Ty pamiętasz tylko jedno mocne hasło główne.

ROZDZIAŁ 3

Weryfikacja dwuetapowa (2FA)

Weryfikacja dwuetapowa (2FA - Two-Factor Authentication) to dodatkowa warstwa ochrony. Nawet jeśli ktoś pozna Twoje hasło, bez drugiego składnika nie zaloguje się na Twoje konto.

Jak to działa:

KROK 1	Wpisujesz login i hasło – tak jak zawsze.
KROK 2	Serwis pyta o drugi składnik weryfikacji.
KROK 3	Podajesz kod z SMS lub aplikacji Authenticator.
KROK 4	Dopiero wtedy uzyskujesz dostęp do konta.

Polecane metody 2FA

- ▶ Aplikacja Authenticator (Google/Microsoft)
- ▶ Kody SMS na telefon
- ▶ Klucz fizyczny (np. YubiKey)

Słabsze alternatywy

- ▶ Kod e-mail (bezpieczniejszy niż nic)
- ▶ Pytania zabezpieczające (najsłabsza forma)

✓ **Włącz 2FA wszędzie gdzie to możliwe: e-mail, bank, social media, sklepy internetowe. To kilka sekund przy logowaniu, które mogą uratować Twoje konto.**

ROZDZIAŁ 4

Phishing – jak go rozpoznać

Phishing to metoda oszustwa polegająca na podszywaniu się pod zaufane instytucje (banki, kurierów, serwisy społecznościowe) w celu wyłudzenia danych lub pieniędzy.

Przykład 1: SMS z fałszywą dopłatą do paczki

Dostajesz SMS z informacją, że Twoja paczka wymaga dopłaty 1 zł. Link prowadzi na fałszywą stronę banku lub płatności.

- ! **Sprawdzaj URL** – oryginalny InPost to inpost.pl, nie inpost-doplata.pl.
- ! **Firmy kurierskie** nigdy nie proszą o dopłaty przez SMS z linkiem.
- ! Zanim klikniesz – **zadzwoń** na oficjalną infolinię.

Przykład 2: Fałszywy profil na Instagramie

Profil podszywa się pod znaną osobę lub markę, oferując darmowy iPhone lub nagrodę.

- ! **Weryfikuj nazwę konta** – fałszywy Apple to [apple_official2025](#), nie [apple](#).
- ! Oficjalne profile mają **niebieski znacznik weryfikacji**.
- ! "Darmowy iPhone" nie istnieje – **jeśli coś wygląda zbyt dobrze**, to oszustwo.

Przykład 3: Fałszywy e-mail od banku

E-mail wygląda identycznie jak komunikat z Twojego banku. Prosi o pilne zalogowanie i weryfikację konta.

- ! **Sprawdź adres nadawcy** – kontakt@pko-bank.com to nie kontakt@pkobp.pl.
- ! **Banki nigdy** nie proszą o podanie pełnego hasła przez e-mail.
- ! Linki w e-mailach – **najedź kursorem** i sprawdź dokąd prowadzą.

Przykład 4: Fałszywy panel logowania

Strona wygląda identycznie jak Instagram lub Facebook. Gdy wpisujesz hasło, trafia ono do hakera.

- ! **Zawsze sprawdzaj URL** – instagram-login.net to nie Instagram.
- ! Szukaj ikony **kłódki (HTTPS)** – ale fałszywe strony też mogą ją mieć.
- ! Jeśli coś Cię przekierowało – **zamknij i wejdź ręcznie** na właściwą stronę.

⚠ **ZŁOTA ZASADA: Nigdy nie klikaj w linki z SMS-ów i e-maili dotyczących płatności, logowania czy nagród. Zawsze wchodź na stronę ręcznie wpisując adres.**

ROZDZIAŁ 5

Socjotechnika – hakowanie ludzi

Socjotechnika to manipulowanie ludźmi, a nie technologią. Zamiast hakować komputer, atakujący hakuje człowieka – używając zaufania, strachu lub pośpiechu.

Metoda „Na znajomego” – wyłudzenie BLIK-a

Haker włamuje się na konto Twojego znajomego na Facebooku, a następnie pisze do Ciebie z prośbą o szybki przelew BLIK – najczęściej na zakupy lub pilną opłatę.

- ▶ **Zadzwoń** do znajomego zanim cokolwiek prześlesz – sprawdź czy naprawdę to on pisze.
- ▶ Podejrzane są nagłe, pilne prośby o pieniądze przez Messenger.
- ▶ Haker często tworzy **fałszywe konto** łudząco podobne do znajomego.
- ▶ Kod BLIK jest ważny tylko 2 minuty – właśnie dlatego atakujący **stwarza presję czasu**.

Inne ataki socjotechniczne:

Vishing	Fałszywy telefon od „pracownika banku” lub „IT support”. Proszą o podanie hasła, kodu SMS lub instalację oprogramowania zdalnego dostępu.
Pretexting	Atakujący buduje fałszywą historię (pretext) – np. podszywa się pod ankietera lub technika, by wyciągnąć informacje.
Tailgating	Fizyczne wejście do chronionego miejsca „za plecami” uprawnionej osoby – np. do biura, szkoły, serwerowni.
Quid pro quo	Obietnica czegoś w zamian za informacje lub dostęp – „pomogę Ci z komputerem, tylko powiedz mi hasło”.

⚠ **Atakujący zawsze gra na emocjach: strach („Twoje konto jest zablokowane!”), pośpiech („Masz 5 minut!”) lub zaufanie („Dzwonię z banku”). Zwolnij, zweryfikuj i zawsze dzwoń na oficjalny numer.**

ROZDZIAŁ 6

Fizyczne bezpieczeństwo – co podpinasz do komputera

Nie wszystkie zagrożenia przychodzą przez internet. Złośliwe urządzenia USB mogą zainfekować komputer w ciągu sekund – zanim jakkolwiek antywirus zdąży zareagować.

Czego NIE podłączać do komputera:

- ✗ **Znalezione pendrive'y** – klasyczna metoda ataku. Atakujący celowo zostawia zainfekowane nośniki na parkingu, przed szkołą, w toalecie.
- ✗ **Nieznane kable USB** – istnieją kable wyglądające jak zwykłe ładowarki (np. O.MG Cable), które instalują złośliwe oprogramowanie.
- ✗ **Rubber Ducky i podobne** – urządzenie wygląda jak pendrive, ale po podłączeniu zachowuje się jak klawiatura i wpisuje złośliwe polecenia.
- ✗ **Ładowarki z nieznanych źródeł** – nigdy nie używaj ładowarek pozostałych w miejscach publicznych ani pożyczonych od nieznanych osób.

⚠ **Złota zasada: Jeśli nie wiesz skąd pochodzi urządzenie USB – nie podłączaj go. Znalezionego pendrive'a zgłoś nauczycielowi, administratorowi IT lub po prostu wyrzucić.**

ROZDZIAŁ 7

OSINT - ile można wyczytać ze zdjęcia

OSINT (Open Source Intelligence) to zbieranie informacji z ogólnodostępnych źródeł. Zaskakujące ile danych o sobie ujawniamy codziennie przez zdjęcia i posty w social mediach.

Kody QR - niewidoczne zagrożenie:

Kod QR na zdjęciu lub w poście to bezpośredni link do strony lub usługi. Osoba, która zobaczy Twój kod QR, może go użyć do:

- ▶ Zalogowania się do Twojego Wi-Fi
- ▶ Dołączenia do Twojej rozmowy WhatsApp Web
- ▶ Zeskanowania Twojego biletu / kodu rabatowego
- ▶ Śledzenia Cię przez QR z danymi lokalizacyjnymi

Jak łatwo dorobić klucz:

Jedno wyraźne zdjęcie klucza (np. w mediach społecznościowych) wystarczy specjaliście ślósarskiemu lub osobie z drukarką 3D, by wyciąć dokładną kopię. Nie fotografuj i nie publikuj zdjęć kluczy.

Czego NIE wrzucać do internetu:

- ✗ **Zdjęcia dowodu osobistego / paszportu** – dane z dokumentu wystarczają do kradzieży tożsamości.
- ✗ **Zdjęcia kart płatniczych** – numer karty, data ważności, często widoczny CVV – gotowe dane do zakupów online.
- ✗ **Bilety lotnicze i na koncerty** – kod kreskowy lub QR można użyć do odprawy zamiast Ciebie.
- ✗ **Zdjęcia kluczy do mieszkania** – wystarczy jedno wyraźne zdjęcie by zrobić duplikat.
- ✗ **Informacja o wyjeździe z datami** – złodzieje monitorują social media szukając pustych domów.

⚠ Przed publikacją zdjęcia zadaj sobie pytanie: „Co mógłby z tego odczytać ktoś z złymi zamiarami?” Metadane zdjęć (EXIF) często zawierają dokładną lokalizację GPS.

ROZDZIAŁ 8

Co robić gdy dojdzie do ataku?

Każdemu może się zdarzyć błąd. Najważniejsze to działać szybko i we właściwej kolejności.

SYTUACJA 1: Kliknąłem/am w link i podałem/am hasło

- 1** Natychmiast zmień hasło na tym portalu (i wszędzie, gdzie używasz tego samego hasła).
- 2** Sprawdź, czy na koncie nie ma nieznanych sesji/urządzeń i wyloguj je wszystkie.
- 3** Włącz weryfikację dwuetapową jeśli jeszcze jej nie masz.
- 4** Sprawdź skrzynkę e-mail czy nie zostały wysłane wiadomości bez Twojej wiedzy.
- 5** Poinformuj znajomych, że Twoje konto mogło być skompromitowane.

SYTUACJA 2: Ktoś ukradł mi konto na FB/Instagramie

- 1** Skorzystaj z opcji „Zapomniałem hasła” i odzyskaj dostęp przez e-mail lub telefon.
- 2** Jeśli e-mail też został zmieniony – użyj opcji „To nie ja” lub „Zgubiłem dostęp do numeru”.
- 3** Na Facebooku: facebook.com/hacked – specjalny formularz dla skradzionych kont.
- 4** Po odzyskaniu konta: zmień hasło, włącz 2FA, sprawdź aplikacje z dostępem.
- 5** Poinformuj znajomych, że konto było zhakowane.

SYTUACJA 3: Wysłałem/am kod BLIK oszustowi

- 1** Natychmiast zadzwoń na infolinię swojego banku (numer z tyłu karty).
- 2** Poproś o zablokowanie transakcji BLIK – masz dosłownie minuty na reakcję.

- 3** Zgłoś sprawę na policję – zrób to osobiście lub przez internet: policja.gov.pl.
- 4** Zabezpiecz dowody: zrzuty ekranu rozmowy, numery telefonów, adresy profili.
- 5** Bank może odmówić zwrotu jeśli sam autoryzowałeś transakcję – działaj jak najszybciej.

ROZDZIAŁ 9

Podsumowanie i checklisty

Wydrukuj lub zapisz te checklisty jako przypomnienie dla siebie i bliskich. Regularnie sprawdzaj czy stosujesz te zasady.

Silne hasła

- ☐ Minimum 12 znaków, wielkie/małe litery, cyfry, znaki specjalne
- ☐ Unikalne hasło dla każdego serwisu
- ☐ Brak danych osobowych, dat urodzenia, imion
- ☐ Brak popularnych wzorców (12345, qwerty)

Menedżer haseł i 2FA

- ☐ Zainstalowany i używany menedżer haseł (Google/Apple/Microsoft)
- ☐ Weryfikacja dwuetapowa włączona na: e-mail, banku, social media
- ☐ Aplikacja Authenticator zainstalowana na telefonie

Phishing i socjotechnika

- ☐ Sprawdzam URL przed kliknięciem (szczególnie w SMS i e-mail)
- ☐ Nie podaję danych/haseł na prośbę przez telefon
- ☐ Prośby o BLIK weryfikuję telefonicznie (na znany numer)
- ☐ Zbyt dobre oferty oznaczają oszustwo

Fizyczne i OSINT

- ☐ Nie podłączam nieznanych urządzeń USB
- ☐ Nie publikuję zdjęć dokumentów, kart, kluczy, biletów

DZIĘKUJEMY ZA UWAGĘ

Projekt SafeLabs

Autorzy projektu	Opiekunowie
Kamil Zdebski Mikołaj Piech Oskar Minor Oskar Miedziński Oscar Mika Emilia Zawada	P. Daniel Sikora P. Oskar Kowalski

Partnerzy projektu: ZSTiB Brzesko • MOK Brzesko • Biblioteka Brzesko • Uniwersytet III Wieku

safelabs.pl • Bezpłatne szkolenia z cyberbezpieczeństwa dla szkół i seniorów